

Big Data Analysis with LDA for Cybersecurity in Organizations

Jingwei HUANG ^{a,1}, Yves LaCerte ^b and Zbigniew KALBARCZYK ^c

^aOld Dominion University

^bJEPPESEN

^cUniversity of Illinois at Urbana-Champaign

Abstract. Cyber security is a great challenge for organizations. Big Data and Machine Learning can be used to improve cyber security protection mechanisms for organizations. This article presents two applications of Latent Dirichlet Allocation (LDA) model for cyber defense. In the first application, we present how to use LDA to discover users' possible hidden intentions from a collection of the user's operations extracted from a very large volume of security monitoring data. This new application can help intrusion detection and malicious activities conducted by insiders. In the second application, we present an architecture used for identifying and redacting sensitive information from outgoing emails in an organization, which may help an enterprise or organization to protect their sensitive information from both intended or unintended leak.

Keywords. Big data, cybersecurity, intrusion detection, insiders, anomaly detection, sensitive information identification, information redaction

1. Introduction

Cybersecurity has been a great challenge for every enterprise and organization. With the trend of Big Data generation and utilization as well as Cloud Computing, on one hand, cybersecurity is becoming more important and more challenging for organizations and enterprises [1]; on the other hand, Big Data and data analytics also provide new opportunities and approaches for enterprises and organizations to enhance their Security Incident and Event Management (SIEM) [1, 2]. In this article, we discuss potential novel applications of Latent Dirichlet Allocation (LDA) [3, 4] in organizational cyber defense. In the following, first of all, we briefly introduce LDA model, which is a successful and broadly used model in natural language processing and text mining; then we discuss how to use LDA for discovering behavior patterns from security monitoring for intrusion and anomaly detection; given the fact that organizations need a significant amount of cross security domain and cross organization communications, we also discuss how to use LDA for identifying sensitive information from outgoing emails in an organization; we give a brief summary in the end.

¹ Corresponding Author, Old Dominion University; E-mail: j2huang@odu.edu

2. Latent Dirichlet Allocation

Latent Dirichlet Allocation [3, 4] is a powerful topic modeling technique developed in Natural Language Processing and Machine Learning. LDA is able to identify the latent semantics of raw data, e.g. topics of text, and has been successfully used in large scale information retrieval and document classification. Topic modeling uses statistical methods analyzing the words of a large archive of documents, to discover themes or topics of the documents [3, 4]. In topic modeling, *word* is the basic unit of data to be processed; *vocabulary* is a set of selected words (or key words) specially interesting to the purpose of topic modeling; a *corpus* is a large collection of documents, from which topics are to be identified; a document naturally consists of a sequence of words, and is about some “topics”, which do not appear explicitly and need to be identified. Topic models are based on word occurrence frequency and “bag of words model”, by which a *document* is regarded as an unordered collection of words, disregarding grammar and word order. The basic idea of topic modeling is as follows: a *document* is modeled as a mixture of *topics*, more exactly, a probability distribution over a set of candidate *topics*, called *topic distribution*; a *topic* is modeled as *topic-word distribution*, which is a probability distribution over the *words* in the *vocabulary*. All documents in the corpus share the same set of candidate topics; but each document has a different topic distribution. Each document consists of words explicitly, but topics are implicit, so that topics are regarded as the latent semantics of a document. Topic modeling aims to identify from a corpus the topic-word distribution and the topic distribution of each document, to make the words generated from those distributions have a word distribution as close as possible to the original word distribution of each document.

The generative process of topic models can be described as follows. The process generates D documents; for document d , generates N_d words; each word is generated by selecting a topic first, then selecting a word based on the assigned topic, that is,

$$P(w_i) = \sum_{j=1}^{|T|} P(w_i | z_j) P(z_j) \quad (1)$$

where $i=1, \dots, |V|$, V is the vocabulary (key word list); w_i denotes the selection of the i th word in V for a document; $|T|$ is the size of topic set; z_j denotes the selection of topic j for a document. LDA is a representative topic model, which extends the above general model by introducing Dirichlet prior.

The generative process of LDA can be described as follows. As shown in figure 1, the LDA generative process generates D documents; for document d , generates N (or N_d for different document size) words; each word is generated by first assigning a topic from K topics, based on the topic distribution, then selecting a word based on the assigned topic and the topic-word distribution. In figure 1, α is Dirichlet prior for topic distribution; θ_d is multinomial distribution over topics for document d ; $z_{d,n}$ denotes the assignment of a topic for selecting the n th word in document d ; η is Dirichlet prior for topic-word distribution; β_k is multinomial distribution over words for a given topic k (i.e. topic k is assigned to $z_{d,n}$); $w_{d,n}$ denotes the selection of the n th word in document d .

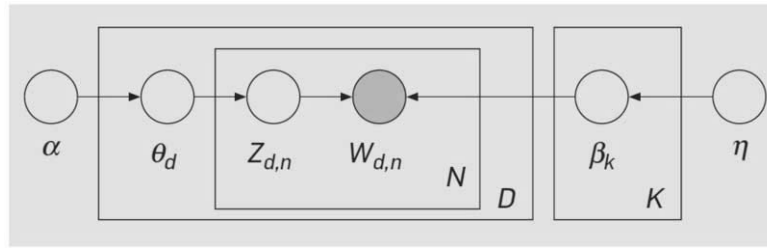


Figure 1. The graphic representation of LDA [4].

Topics can be identified through learning from corpora by algorithms such as expectation maximization (EM) [5], Gibbs sampling [6], and variational Bayes learning [7]. For the needs of handling big data, LDA can be implemented in parallel processing paradigms such as using MapReduce [8, 9] or Spark [10].

3. Behavior Pattern Discovery from Big Data for Intrusion Detection

With rapid adoption of cloud computing, the workflow of an organization becomes much complex and across security domains; therefore, enterprises and organizations are facing more challenging tasks of cyber defense from security policies to intrusion and anomaly detection.

Many intrusion and anomaly detection technologies have been developed [11, 12]; signature-based technologies catch the known attacks effectively, but are not effective to the rapid growing new types of attacks; anomaly-based technologies detect “abnormal” behaviors, therefore this approach may catch the unknown attacks but typically has high false positive rate. We aim to explore a new approach to knowledge discovery from big data for intrusion detection by using LDA. We envision that intrusion detection can be mapped into a topic modeling problem and be solved by a LDA approach. This LDA approach is a hybrid approach, which may complement the features of signature-based and anomaly-based approaches, to detect malicious behaviors of both intruders and insiders.

Particularly, in more recent years, organizations are facing more and more intensive challenges from stealthy Advanced Persistent Threat (APT) attacks [13]. “APTs are operated by highly-skilled, well-funded and motivated attackers targeting sensitive information from specific organizations and operating over periods of months or years” [2]. This makes the detection of APTs very difficult. Traditional SIEM systems typically can only keep security monitoring data for a small time window, for example, 60 days. Facilitated by Big Data solutions, the presented LDA approach can help to detect (APT) attacks in a much wider time windows.

National Center for Supercomputing Applications (NCSA) collects a large volume of forensic data from security monitoring and system logs every day; those data are also in many different formats, because they are generated from a variety of monitoring systems. Those data are a rich source for security knowledge discovery and intrusion detection; at the same time, those big data and the complexity of the problems also present a great challenge.

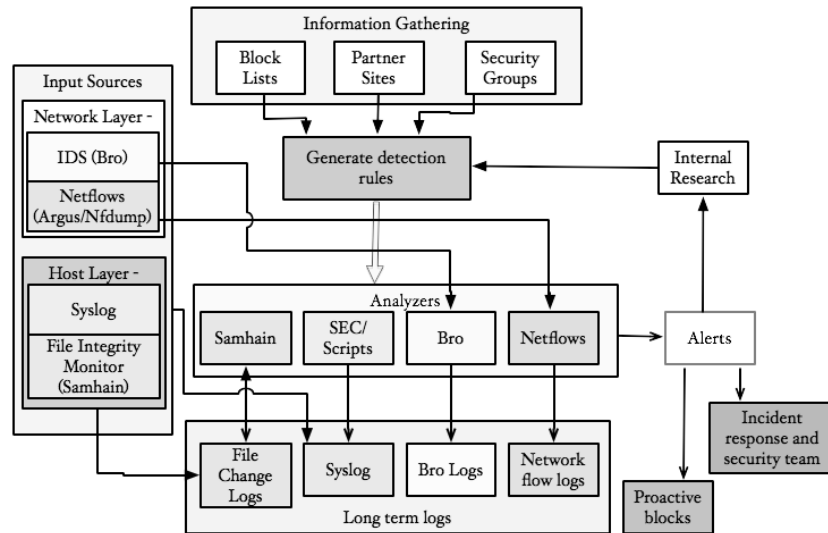


Figure 2. Monitoring Architecture Deployed at NCSA [14]

In NCSA, security is monitored at both network and host layers, as illustrated in 2. At the network layer Bro IDS is used to perform deep packet inspection of network traffic going through the border router for detection of anomalous activity. 4.5GB of logs are collected daily. The network flow (netflow) collectors, such as *Argus* and *nfdump*, are distributed such that flows are monitored and logged from the border router and from the internal routers. The measurements give visibility to traffic within the internal subnets as well as to the traffic going in and out of the network. 2GB of netflow logs are collected daily. In host layer, operations are logged by *syslog* and file change logs are generated by the *File Integrity Monitor*. When moving to new generation of supercomputing, the amount of collected data grows rapidly, e.g. BlueWaters (petascale facility in NCSA) collects 3.7TB of syslogs over its first 336 days of services. Based on those logs, also blacklists and other external information from partners' sites, as well as security policies, security analysis tools generate various alerts for anomalies and signature matches [14, 15].

3.1. Approach

In order to use LDA for intrusion detection, we need to map the intrusion detection problem into the topic modeling problem. To this end, the list of all monitored events is regarded as “*vocabulary*”; a logged event is regarded as a “*word*” in that *vocabulary*; each type of security incidents (such as intrusion or anomalies caused by insiders) is regarded as a “*topic*”, which is represented by a probability distribution over the *words* (in the *vocabulary*); typical types of normal operations are also regarded as *topics*; a collection of events done by a user in a period of time is regarded as a “*document*”; a *document* is a mixture of *topics*, i.e. a *document* is modelled as a probability distribution over *topics*; a collection of all *documents*, i.e. all sets of logged events, is called a *corpus*, from which *topics* are identified through LDA

learning. In runtime, the *topic distribution* of each new “document” (a set of new logged events) is calculated; if a new *document* has a high probability distribution over some security breach *topics*, then this set of logged events represented by that *document* may be a security breach, and a security warning should be issued.

3.2. A Use Case

To illustrate the above approach, consider the following scenario. Let us assume that the following list of possible types of events are monitored and collected by security monitoring systems.

- w1: login from an unknown IP address, according to the user profile;
- w2: multiple logins from the same IP address (multiple users use the same external IP address to sign in);
- w3: SSH connection;
- w4: suspicious IRC (Internet Relay Chat) connection (e.g. IRC traffic on a non-standard port);
- w5: internal scan;
- w6: external scan;
- w7: SSH scan;
- w8: downloading from publicly available exploit repositories or watching list;
- w9: rename file types;
- w10: connections to an unused IP block within the network;
- ...

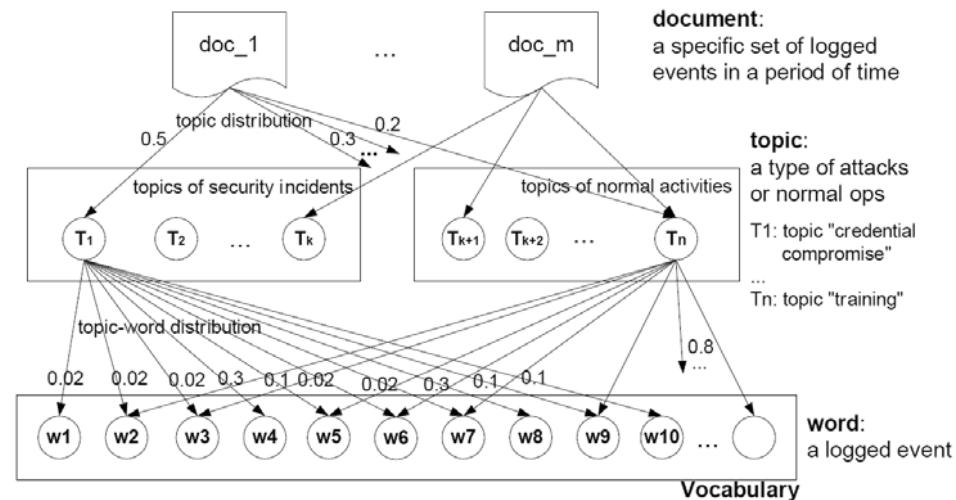


Figure 3. Example of LDA modeling for intrusion detection

The collection of those event types forms the *vocabulary*, as shown in the bottom level in figure 3. In the figure, each “document” represents a set of the logged operations conducted by a user (a legitimate user or an intruder/malicious

insiders/malware) in a specific period of time; each “word” in the document represents a logged event.

What a user is trying to do is unknown to the security monitoring system; however, *although a single event does not reveal the user’s intent, a collection of logged events may reveal the intent*. This hidden intent, or latent semantics in the terminology of topic modeling, is modeled as a “topic”, which is defined as a probability distribution over the *vocabulary* (the set of monitored events), called *topic-word distribution*. In this way, each *topic* represents a class of security incidents, e.g. *credential compromise*; or represents a class of normal activities conducted by users, e.g. “IT training”. The *topics* are illustrated in the middle level in figure 3. The “topics” of a “document” (a set of logged events) do not appear explicitly as words do, but can be identified by using LDA modeling.

Assume that based on an in-depth analysis of data logs on security incidents, we established that topic *credential compromise* has a probability distribution over a set of logged events (“words”), as shown in fig. 3. Similarly, there exist *topics* corresponding to the normal behavior of a legitimate user, e.g. *training*. Those topics (defined by topic-word distributions), illustrated in the middle layer in fig. 3, can be identified or learnt from a set of *documents* (a collection of all security logs and alerts) by using a LDA algorithm.

At runtime, a new “document”, i.e. a set of new logged events, associated with observable system activities over a predefined period of time, is collected. Based on the logged events (*words*) contained in the *document*, its topics distribution is calculated as follows: “credential compromise” (0.5), “Training” (0.2), and other *topics* of legitimate activities (0.3). The obtained probability distribution indicates that the observed behavior corresponds in a high probability to a security incident *credential compromise* (rather than legitimate activity); hence an alert should be raised.

Generally, the security incident *topics* represent malicious behavior; the normal activity *topics* represent normal behavior; so, in the topic distribution of a *document*, if a probability on a security incident *topic* is higher than a predefined threshold, an alert should be issued; if the probabilities on normal activity *topics* are fairly high and the probabilities on all security incident *topics* are lower than their thresholds, the behavior reflected by the *document* can be regarded as normal; if all probabilities on all *topics* are low and there exist a big error between the *document* (the real set of logged events) and the generated *document* from LDA topic model, then it is the sign of that the behavior reflected by the *document* is beyond the current *topics*, and further investigation needs to be conducted.

3.3. Further Discussion

We presented a hybrid approach to knowledge discovery from big data for intrusion detection using LDA, in which the *topics* capture the “patterns” of both security incidents and normal activities, by using “bag of words” and probability distribution, so that this new pattern representation has flexibility to capture attacks in a wider range. More interestingly, the topics identified by LDA catch the latent semantics of a collection of the logged events, which gives a higher level description about what a user is doing or intends to do by that specific set (or sequence) of operations. This latent semantics is critical to intrusion detection, and can be identified by LDA model. From Spark 1.3, LDA has been included in Spark’s machine learning library MLlib;

thus technically feasible to handle a very large volume of logs and to conduct LDA learning in a timely manner.

4. Semantic Redaction for Sensitive Information

Modern military activities such as warfighting, intelligence, and other business activities need a significant amount of cross domain and cross organization communications. Automatic redaction can largely help military agencies to prevent sensitive information from releasing to unauthorized entities. We study redaction issue through a concrete example – a messaging system. An outgoing message, e.g. an email and its attached files, may contain some sensitive information (classified information or unclassified sensitive information bearing non-hierarchical security marks); the message recipients may have different security clearance and work for different organizations and/or countries; there are need-to-protect and need-to-share requirements expressed as policies on information access and use; the message sender may carelessly or maliciously send sensitive information to recipients who do not have sufficient security clearance or other security attributes (such as citizenship) required by policies to see the information. The research question to us is how to redact the outgoing message to create for each recipient a redacted version that conforms to those policies. If all information items contained in an outgoing message have security marks, then we can use access control policies to make redaction decisions based on who can read what information item. However, in communication, emails and many exchanged files, which are raw text without any security marks and may not go through formal security classification, may reveal sensitive information. How to detect whether or not a piece of outgoing raw text without security marks contains sensitive information is a big challenge.

We aim to develop technologies to solve this challenging problem of redaction. Our research objectives are: (1) to develop a system solution of automatic redaction of sensitive information in cross-domain and cross-organization communication; (2) particularly, to develop technologies for the challenging problem of detecting sensitive information from raw text without security marks; (3) to develop a prototype system to demonstrate our solution.

We discuss our solution in two steps: (1) basic solution, focusing on the system design of redaction system; (2) advanced solution, focusing on automatic detection of sensitive information from raw text without security marks.

4.1. Redaction System Design

A high level abstraction of our idea about the architecture of a redaction system, called **STREK** (SemanTic REdaction Kernel), is illustrated in figure 1. STREK can be employed by a messaging system in an organization. When a message sender sends out a message to a list of recipients, STREK checks what contents of the outgoing message cannot be read by each specific recipient, and to create for each recipient a redacted version, which replaces contents unauthorized to that recipient with black rectangles; then the messaging system sends to each specific recipient a redacted version of that message. STREK mainly needs three functionalities:

- Identification (or detection) of sensitive information from outgoing messages (including attached documents): minimally, STREK only identifies the

contents having security marks; we will discuss advanced technology to detect sensitive information from raw text without security marks in advanced solution.

- Redaction decision: STREK calls a policy engine to make a decision (permit/deny) for each pair of identified sensitive information and a recipient. Dependent on needs, STREK could use either a stand-alone policy engine implemented with XACML or the organization's access control policy engine.
- Document redaction: based on a list of access request decisions, STREK creates for each specific recipient a redacted version, in which if the decision on the read-access by that recipient to an identified sensitive item is "deny", then the text corresponding to that sensitive item is replaced with a black rectangle.

The implementation of both identification of sensitive information and document redaction are dependent on the document formats of messages. We consider PDF format as an example; other formats such as MS Word can be handled in a similar manner but with different word-processing techniques. We can integrate available PDF redaction technologies such as the one used in Redax into STREK; particularly, we can extend XMP (Extensible Metadata Platform), the metadata language for PDF, to express security marks and DDMS metadata. DDMS (DoD Discovery Metadata Specification) [16] is DoD's metadata standard for secure data sharing. The metadata categories defined in DDMS cover security and provenance, e.g. classification (sensitivity level only), creator, publisher, contributor, date of creating, posting, and expiration, subject-coverage, geospatial coverage, temporal coverage, related resources and relationships. The DDMS metadata could be used for redaction decision making by checking relevant security policies [17, 18].

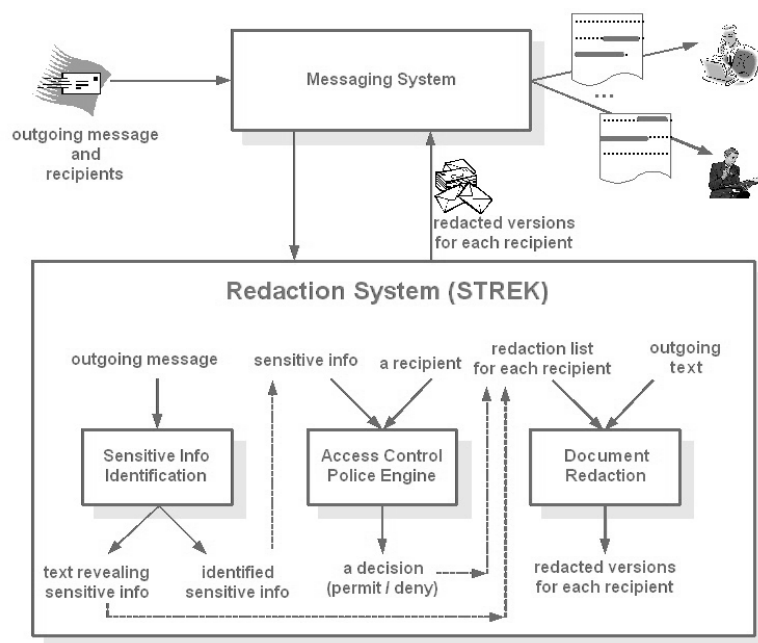


Figure 4. An outline of the architecture of a redaction system, STREK.

The presented STREK and its components can be developed as a set of cloud services, and assume them operating in a private cloud dedicated to a specific security domain. STREK as a cloud service can be employed by the messaging system of an organization or other network control point; policy engine itself is a cloud service and integrated in STREK as a “virtual” component.

4.2. Detection of Sensitive Information from Raw Text

Detecting sensitive information from raw text is the challenging problem which we wrestle with. Our basic idea is to devise a quantitative representation of text, which can be used to measure the semantic distance between the outgoing text and the text of classified information.

The first challenge we are facing is how to represent the semantics of text. Typically, semantics can be represented by the models developed in knowledge representation, e.g. semantic networks and ontologies. However, in general, those models are domain-dependent and their development could be labor-intensive. Topic distribution developed in *topic modeling* [19, 6] has potential to serve as a general tool for semantic representation of text.

Topic modeling is a technology developed in Natural Language Processing and Machine Learning. Topic models (e.g. pLSI [5], Latent Dirichlet Allocation (LDA) [3]) can identify the latent semantics (or topics) in text and has been used in information retrieval and document classification. Topic models are based on word occurrence frequency and “bag of words model” (in which a document is represented as an unordered collection of words, disregarding grammar and word order.) In a topic model, typically, a document is modeled as a mixture of topics, more exactly, a probability distribution over a set of topics, called *topic distribution*; a *topic* is modeled as a probability distribution over a list of words (called vocabulary). Topics can be extracted by learning from corpus. From the extracted topics, the topics of a document can be inferred.

In the context of redaction, some topics can be regarded as sensitive topics; however, many topics of classified information may be also popular topics appearing in mass media. Therefore in most situations, topics alone are not sufficient as criteria to identify sensitive information. However, topic modeling can help.

In the following, we discuss how we use topic modeling to develop a model of sensitive information detection from raw text. We have a vision that the topic distribution of a piece of text over the topic space extracted from large corpora can be regarded as the “chromosome” of that text, and the possibility for two pieces of text to have the same chromosome is small. Our approach, as shown in figure 2, is outlined as follows. (1) Learn topics from a large set of sensitive information, by using a learning algorithm of topic modeling. We will also study a hybrid learning algorithm, which enables human experts to import known topics, and uses entropy and some semantic constraints to improve the meaningfulness of extracted topics. (2) Calculate the topic distribution of each piece of text of sensitive information. Topic distribution can be calculated with a determinate model, and the result’s meaningfulness will be evaluated by using semantic constraints and entropy. For example, an even distribution over many topics is less meaningful. The model and parameters used will be saved as provenance metadata associated with the outcome topic distribution. (3) Store and index each sensitive text’s topic distribution.

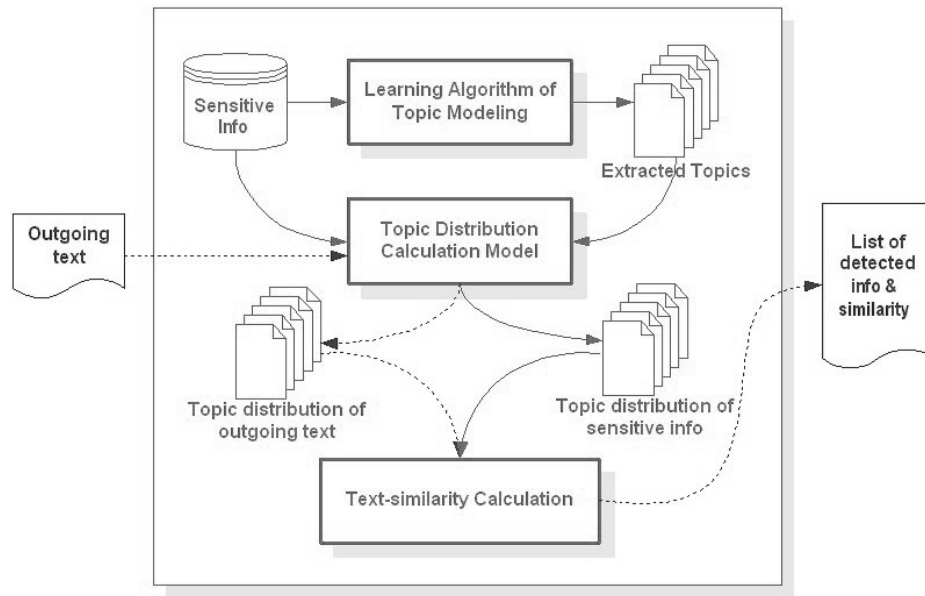


Figure 5. A model of sensitive information detection from raw text without security marks.

(4) Calculate the topic distribution of each piece of text in an outgoing message (including its attached documents). For a piece of text, its topic distribution may be calculated with several different provenance metadata, corresponding to similar sensitive items. (5) Calculate text-similarity index, as in [6], by comparing the topic distribution of each piece of outgoing text with the stored topic distribution of each sensitive text relevant to the outgoing text. Since topics may be correlated [20], we consider the relations among topics when to measure text-similarity. (6) If a piece of outgoing text and a piece of sensitive text have the exactly same topic distribution (chromosome), then these two pieces of text are the same in high possibility; access control policies should be applied to decide whether or not to redact that text for a specific recipient. (7) If the calculated text-similarity index is greater than a threshold, which means that the outgoing text may rephrase or is semantically similar in a certain degree to a piece of sensitive information, then a warning should be given. There may be different thresholds for several warning levels.

To enhance the capabilities of sensitive information detection and redaction, we could also integrate other NLP/IR technologies complementary to this model into STREK. For example, in some situations an individual's social security number should be redacted for privacy protection. We can use regular expressions to identify the contents to be redacted in outgoing text, especially in short text.

The presented approach of sensitive information detection has potential to detect whether an outgoing text contains original text or part of text of sensitive information items, and to give warnings if an outgoing text appears to reveal sensitive information.

5. Concluding Remarks

In this article, for the purpose of cyber defense in organizations, we presented potential novel applications of LDA in user hidden behavior pattern discovery for detecting malicious users including both intruders and insiders, and in sensitive information identification and/or redaction in outgoing emails in an organization. Without support of Big Data, traditional SIEM systems typically can only keep security monitoring data for a narrow time window (e.g. 60 days). Together with Big Data solutions, the presented hidden behavior pattern discovery with LDA can help intrusion and anomaly detection in much broader time windows, particularly in coping with the growing stealthy Advanced Persistent Threat (APT) attacks.

References

- [1] NIST Big Data Public Working Group. NIST big data interoperability framework: Volume 4, security and privacy, Sept. 2015.
- [2] Cloud Security Alliance - Big Data Working Group. Big data analytics for security intelligence, Sept. 2013.
- [3] D. M. Blei, A. Y. Ng, and M. I. Jordan. Latent dirichlet allocation. *J. Mach. Learn. Res.*, 3:993–1022, 2003.
- [4] D. M. Blei. Probabilistic topic models. *Commun. ACM*, 55(4):77–84, 2012.
- [5] T. Hofmann. Probabilistic latent semantic indexing. In *Proceedings of the 22nd annual international ACM SIGIR conference on Research and development in information retrieval, SIGIR '99*, pages 50–57, New York, NY, USA, 1999. ACM.
- [6] M. Steyvers and T. Griffiths. *Probabilistic Topic Models*. Lawrence Erlbaum Associates, 2007.
- [7] M. D. Hoffman, D. M. Blei, and F. Bach. Online learning for latent dirichlet allocation. In *Neural Information Processing Systems*, 2010.
- [8] J. Dean and S. Ghemawat. Mapreduce: Simplified data processing on large clusters. In *OSDI 2004*, pages 137–150, 2004.
- [9] T. White. Hadoop: the definitive Guide, 4th Edition. O'Reilly, 2015.
- [10] M. Zaharia, M. Chowdhury, M. J. Franklin, S. Shenker, and I. Stoica. Spark: Cluster computing with working sets. In *Proceedings of the 2Nd USENIX Conference on Hot Topics in Cloud Computing, HotCloud'10*, pages 10–10, Berkeley, CA, USA, 2010. USENIX Association.
- [11] P. Garcia-Teodoro, J. Diaz-Verdejo, G. Macia-Fernandez, and E. Vazquez. Anomaly-based network intrusion detection: Techniques, systems and challenges. *Computers & Security*, 28:18 – 28, 2009.
- [12] V. Chandola, A. Banerjee, and V. Kumar. Anomaly detection: A survey. *ACM Comput. Surv.*, 41(3):15:1–15:58, July 2009.
- [13] C. Tankard. Advanced persistent threats and how to monitor and deter them. *Network security*, 2011(8):16–19, 2011.
- [14] A. Sharma, Z. Kalbarczyk, J. Barlow, and R. Iyer. Analysis of security data from a large computing organization. In *Proc. DSN'2011*, pages 506–517.
- [15] A. Pecchia, A. Sharma, Z. Kalbarczyk, D. Cotroneo, and R. K. Iyer. Identifying compromised users in shared computing infrastructures: A data-driven Bayesian network approach. In *Proc. SRDS'2011*, pages 127–136.
- [16] DoD. DoD Discovery Metadata Specification (DDMS) Version 4.1, June 2012. <http://metadata.ces.mil/mdr/irs/DDMS/>.
- [17] J. Huang and D. Nicol. Security and provenance in m3gs for cross-domain information sharing. In *MILCOM 2012 - 2012 IEEE Military Communications Conference*, pages 1–6, Oct 2012.
- [18] J. Huang, D. M. Nicol, R. Bobba, and J. H. Huh. A framework integrating attribute-based policies into role-based access control. In *Proceedings of the 17th ACM Symposium on Access Control Models and Technologies, SACMAT '12*, pages 187–196, New York, NY, USA, 2012. ACM.
- [19] D. M. Blei and J. D. Lafferty. *Topic Models*. Taylor and Francis, 2009.
- [20] D. M. Blei and J. D. Lafferty. Correlated topic models. In *NIPS*, 2006.

The author(s) of this publication is/are solely responsible for its content. This publication does not reflect the opinion of the publisher. The publisher cannot be held liable for any loss or damage that may occur because of this publication.